Relatório de Arquitetura Cloud Segura (AWS)

Projeto: `nhsneto/arquitetura-aws-segura`
Diretriz Estratégica: Defesa em Profundidade e Zero Trust
Topologia: VPC Multi-Tier (10.0.0.0/16) — Região: sa-east-1

1. Visão Geral da Arquitetura de Rede

A arquitetura foi rigorosamente projetada para atender aos requisitos de isolamento, resiliência e confidencialidade. Nenhum componente interno possui endereço IP público ou rota direta de entrada pela Internet. A infraestrutura está particionada da seguinte forma:

- **Sub-redes Públicas (Borda):** Hospedam exclusivamente o Application Load Balancer (ALB), que atua como ponto único de entrada e redirecionamento HTTPS.
- **Sub-redes Privadas de Aplicação:** Alojamento das instâncias EC2 da API Backend (porta TCP 3000) e do endpoint AWS Client VPN. Não possuem IP público.
- **Sub-redes Privadas de Dados:** Isolamento estrito para o cluster Amazon RDS MySQL em implantação Multi-AZ, protegido contra qualquer tráfego que não venha da aplicação.

2. Justificativas das Decisões de Segurança

2.1. Isolamento e Superfície de Ataque Reduzida

A segmentação em VPC Multi-Tier bloqueia passivamente varreduras de rede e ataques de negação de serviço direto aos servidores. Ao dispensar NAT Gateways, optou-se pelo uso de **VPC Endpoints (Gateway e PrivateLink)**. Isso assegura que o tráfego destinado a serviços da AWS (Amazon S3, Secrets Manager, KMS, CloudWatch) transite unicamente pelo *backbone* privado da AWS, anulando o vetor de exfiltração de dados para a internet pública.

2.2. Controle de Acesso e Privilégio Mínimo

A postura de Zero Trust é consolidada pelo **encadeamento de Security Groups** via IDs. O banco de dados não confia em faixas de IP arbitrárias; ele aceita tráfego unicamente do Security Group da aplicação (`app-prod-api-sg`). Além disso, aboliu-se o acesso administrativo tradicional. Toda a gestão das instâncias ocorre via **AWS Systems Manager (Session Manager)**, eliminando portas abertas (como a TCP 22/SSH), chaves assimétricas estáticas e Bastion Hosts, o que mitiga vulnerabilidades de força bruta.

2.3. Proteção de Dados e Defesa Camada 7 (WAF)

O **AWS WAF** intercepta o tráfego público antes mesmo de ser entregue às instâncias, neutralizando tentativas de SQL Injection, Cross-Site Scripting (XSS) e tráfego anômalo de *bots*. Dados sensíveis e credenciais nunca constam em código-fonte ou texto plano, sendo recuperados em tempo de execução via *IAM Roles* utilizando o AWS Secrets Manager. O armazenamento de arquivos no S3 bloqueia exposições indesejadas por meio da funcionalidade *Block Public Access*, aliada à criptografia *Server-Side* obrigatória (SSE-KMS).

3. Matriz Executiva de Fluxos (Default-Deny)

Vetor / Origem	Destino	Protocolo/Porta	Controle de Segurança (Status)
Internet Pública	ALB (Borda)	TCP 443 (HTTPS)	**Permitido** — Entrada inspecionada pelo AWS WAF e cifrada com TLS (ACM).
ALB (Borda)	EC2 API Backend	TCP 3000	**Permitido** — API EC2 valida a comunicação via ID do Security Group do ALB.
EC2 API Backend	Amazon RDS MySQL	TCP 3306	**Permitido** — Tráfego interno e restrito ao grupo de segurança da aplicação.
Internet Pública	Amazon RDS MySQL	TCP 3306	**BLOQUEADO** — RDS isolado em sub-rede sem rotas públicas. Mitiga ransomware.
Tráfego Lateral / Net	EC2 / Instâncias	TCP 22 (SSH)	**BLOQUEADO** — SSH tradicional fechado. Gestão encapsulada via túnel AWS SSM.

4. Auditoria e Observabilidade

A arquitetura não se apoia apenas na prevenção preventiva, mas investe fortemente na rastreabilidade. A ativação dos **VPC Flow Logs** em todas as interfaces garante registro pericial contínuo de pacotes rejeitados. Simultaneamente, o **AWS CloudTrail** acompanha todas as chamadas de API gerenciais, com alertas proativos integrados ao **Amazon CloudWatch**.

5. Síntese das Decisões de Arquitetura

Este relatório consolida os pilares técnicos do projeto, demonstrando de forma clara as premissas de segurança aplicadas:

- **Zero Trust e Defesa em Profundidade:** Segmentação em camadas rigorosas (Pública, Aplicação e Dados) sem confiança implícita entre elas e sem rotas diretas da internet.
- **Aplicação do Menor Privilégio:** Encadeamento restrito de *Security Groups* por ID (o banco de dados só aceita a API; a API só aceita o Load Balancer), impedindo movimentações laterais caso um recurso venha a ser comprometido.
- **Redução da Superfície de Ataque:** Remoção completa de portas administrativas abertas (como SSH/22) por meio do uso do AWS Systems Manager (SSM) via VPN, além da comunicação 100% interna com serviços AWS por meio de *VPC Endpoints*.
- **Proteção Ativa e Rastreabilidade:** Bloqueio de ameaças Web de Camada 7 na borda com AWS WAF, exigência de criptografia em trânsito e repouso (ACM e KMS) e monitoramento contínuo da infraestrutura.